# CLOUD SECURITY MISCONFIGURATIONS

*("OH LOOK, SOMETHING FLUFFY - POKE, POKE, POKE")*

Kat Fitzgerald evilkat@rnbwmail.com

github.com/rnbwkat/presents
rnbwkat@infosec.exchange
rnbwkat.bsky.social
youtube.com/@rnbwkatandtequila
*(2nd episode being recorded next week)*

theunfrostedfiles.com
sashatheflamingo.xyz

1

## $WHOIAM

*Kat Fitzgerald*

- *CEO @BSidesChicago,*
  *CV Lead @dianainitiative,*
  *CFP Chair @BSidesPGH, DefCon 3!*
- *Based in ~~Chicago~~ Porto and a natural creature of winter, you can typically find me sipping Casa Noblé Añejo whilst simultaneously defending my systems using OSS, magic spells and Dancing Flamingos*
- *Honeypots, Refrigerators and IoT (Internet of Threats) are a few of my favorite things*
- *And.. I love to cook!*

3

# DISCLAIMER

- The views and opinions expressed in this presentation are my own and do not necessarily reflect the official policy or position of any current or previous employer.
- Examples of exploitations, coding and vulnerabilities discussed within this presentation are only examples and they should not be utilized in the real-world.

5

# THE NUMBER THAT SHOULD EMBARRASS US

- I won't teach you how to break-in to the cloud – only "concepts"
- Common Sense went out the window decades ago
- 99% of cloud security failures
- Same root cause
- Every year
- Still

- Complexity is the Enemy of Security!

6

## WHY WE ARE HERE

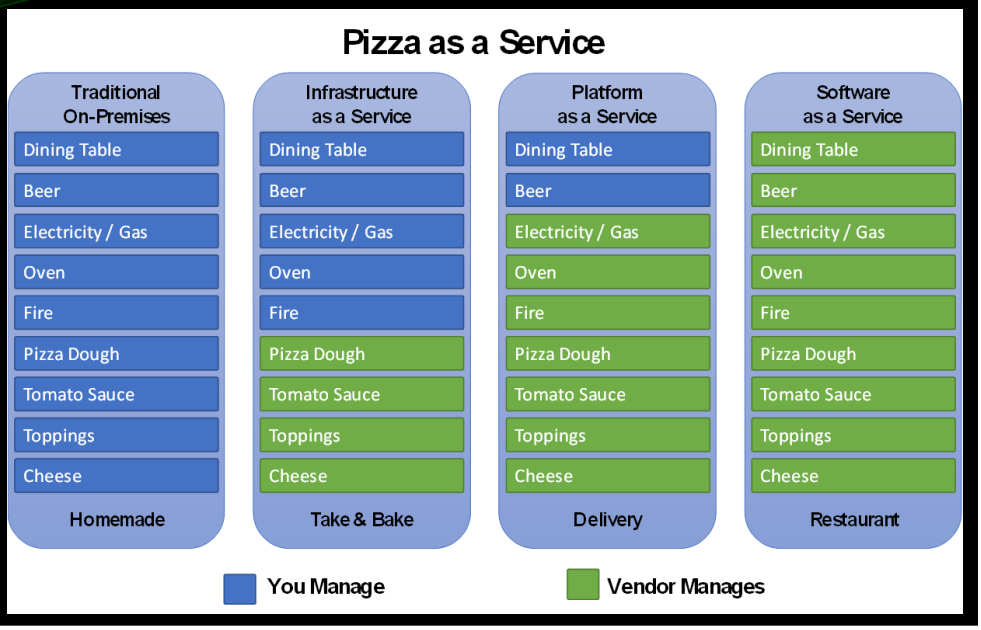
| ***Identity*** | ***Exposure*** | ***Drift*** |
|---|---|---|
| Admin Everywhere | Public Storage | CI/CD Secrets |
| MFA Optional | 0.0.0.0/0 | Plaintext Data |
| Over-Trusted APIs | Misconfigured SGs | Shadow Accounts |
| | No Logging | |
| | No Guardrails | |

*Commonsense is required – disregard previous slide ☺*

7

## CLOUD(S)

- IAM Policies
- ORG Policies
- Network too
- Creds ← FTW!
- Detection!!!




8

# AN INCIDENT

- Most incidents are NOT 0-day
- Most incidents are NOT "fancy"
- Most incidents don't come from "vulnerability scanners"

1. Most breaches come from "Config Issues"
2. A close 2nd - compromised credentials
3. Trailing in 3rd - Over-Priv Users

9

# OWASP A05:2021 SECURITY MISCONFIGURATION

*"Nearly all successful attacks on cloud services are a result of customer misconfiguration, mismanagement and mistakes." –Neil MacDonald, Gartner*

- Two real incidents (2025)
- A hierarchy of how this actually works
- Why complexity is making it worse
- What 'fixing it' actually looks like in 2026

10

## NO THREAT ACTOR REQ'D

April 9, 2025

- 4.7 million members affected
- Health browsing + claims data leaked
- Destination: Google Ads
- Root cause:
  Misconfigured Google Analytics

Tracking data forwarded to ad systems:

- Browsing history
- Plan details
- Claims data
- Running quietly for years

11

## YOUR CLOUD'S CLOUD HAD A CLOUD PROBLEM

Oracle Cloud — 2025

- Misconfigured resources
- Enterprise customer data exposed
- Support files + internal configuration information
- Hundreds of organizations potentially impacted

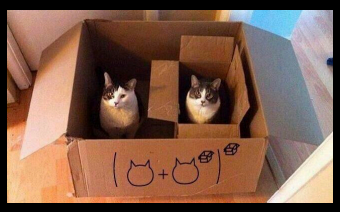
Configuration Gap – Not a "flaw":

- Multi-tenant blast radius
- You secured your environment perfectly
- Inherited

12

# 2 INCIDENTS – SAME CAUSE

| | Blue Shield | Oracle Cloud |
|---|---|---|
| **Attacker?** | None | Config-enabled access |
| **Cause** | Analytics tag | Cloud config gap |
| **Duration** | Years unnoticed | Multi-tenant impact |
| **Category** | Tier 2 SaaS | Supply chain + identity |



13

# THIS WASN'T HACKING, IT WAS PERMISSION!

14

## THE MENU

Tier 1: Identity & Entitlement Overreach

Tier 2: Misconfigured SaaS & API Integrations

Tier 3: Classic Leaky Storage

Tier 4: Shadow Resources & Abandoned Infrastructure

15

## TIER 1: IDENTITY & ENTITLEMENT OVERREACH

- The flaw: 'Admin' or 'FullAccess' for convenience
- Attackers don't steal data — they borrow your permissions
- Multi-cloud pivoting: one compromised identity, two environments
- The network perimeter is gone. Identity is what's left.

16

## TIER 2: THE FASTEST GROWING CATEGORY

- Over-permissive API keys
- Shadow integrations bypassing MFA and logging
- Salesforce. GitHub. Slack. Connected to your core cloud.
- 2025: Small vendor API key → full database read/write

17

## TIER 3 & 4: THE CLASSICS AREN'T DEAD

Tier 3: 'Public Read' is rarer — 'Authenticated User' access isn't

- CDN origin misconfigurations still rampant
- ~9% of publicly accessible storage contains sensitive PII (2025)
  - 12% of companies Encrypt at Rest

Tier 4: IaC made it easy to spin up — and forget

- Dev/test environments without production guardrails, connected to production data

18

# SPECIAL GUEST APPEARANCES

| ***Misconfiguration*** | ***Impact*** | ***Why It's Happening*** |
|---|---|---|
| AI Workload Defaults | High | Most new AI workloads deploy with root-level access for speed |
| K8s Admission Controllers (CVE-2025-1974) | Critical | Misconfigured controllers bypass security checks entirely |
| Plaintext Secret Exposure | High | Hardcoded API keys and passwords still embedded in source code at scale |

19

# WHY WE'RE STILL HERE

Multi-cloud friction:

- AWS muscle memory doesn't translate to Azure IAM

Velocity:

- 'Allow all' for testing. Friday 2 PM deploy.
- You know the rest.

Visibility gap:

- Most enterprises use 2+ cloud providers.
- Less than a quarter have full visibility across all of them.

20

AND…
(JUST A STEP TO THE LEFT…)

PaC FTW!

| | ***Legacy Security*** | ***Policy as Code*** |
|---|---|---|
| ***Detection*** | Days / Weeks | Milliseconds |
| ***Approach*** | Fix after the fact | Block before deployment |
| ***Consistency*** | Human-dependent | Code-enforced |
| ***Developer friction*** | High — tickets, back and forth | Low — instant CLI feedback |

21

## HOW THE CLOUD LEARNS TO SAY "NO"

openpolicyagent.org/docs

- Terraform tries to deploy a public bucket. The pipeline disagrees
- Someone hardcodes a secret. The commit bounces.
- A developer grants * permissions. PaC says no. Nobody argues with PaC
- An admin makes a console change at midnight. It's gone by morning
- The guardrail doesn't care what your deadline is!!!

22

## OUR FIRST POLICIES - THE BIG 5

No public storage buckets

No unencrypted disks

MFA required on all identities

No wildcard IAM permissions

No hardcoded secrets in source

23

## POLICY-FIRST WORKFLOW

- Define your Big 5
- Codify in OPA / Rego - one language, works everywhere
  - Rego is worth the learning curve!!
- Embed in your pipeline - GitHub Actions, GitLab CI, wherever you live
- Enforce and notify - broken build + clear error message beats a ticket a week later

24

# ONCE UPON A TIME (1)

```
7.18 [extra718] Check if S3 buckets have server access logging enabled
FAIL! Bucket 00247[redacted]660497866f has server access logging disabled!
7.29 [extra729] Ensure there are no EBS Volumes unencrypted
INFO! Looking for EBS Volumes in all regions...
FAIL! us-west-1: vol-0e[redacted]d2aba is not encrypted!
FAIL! us-west-1: vol-0e[redacted]678be is not encrypted!
FAIL! us-west-1: vol-0f[redacted]f9297 is not encrypted!
FAIL! us-west-1: vol-09[redacted]0a69b is not encrypted!
FAIL! us-west-1: vol-07[redacted]3c68a is not encrypted!
FAIL! us-west-1: vol-0c[redacted]e761b is not encrypted!
FAIL! us-west-1: vol-0f[redacted]76e46 is not encrypted!
FAIL! us-west-1: vol-08[redacted]4c38b is not encrypted!
FAIL! us-west-1: vol-0c[redacted]a5318 is not encrypted!
```

25

# ONCE UPON A TIME (2)

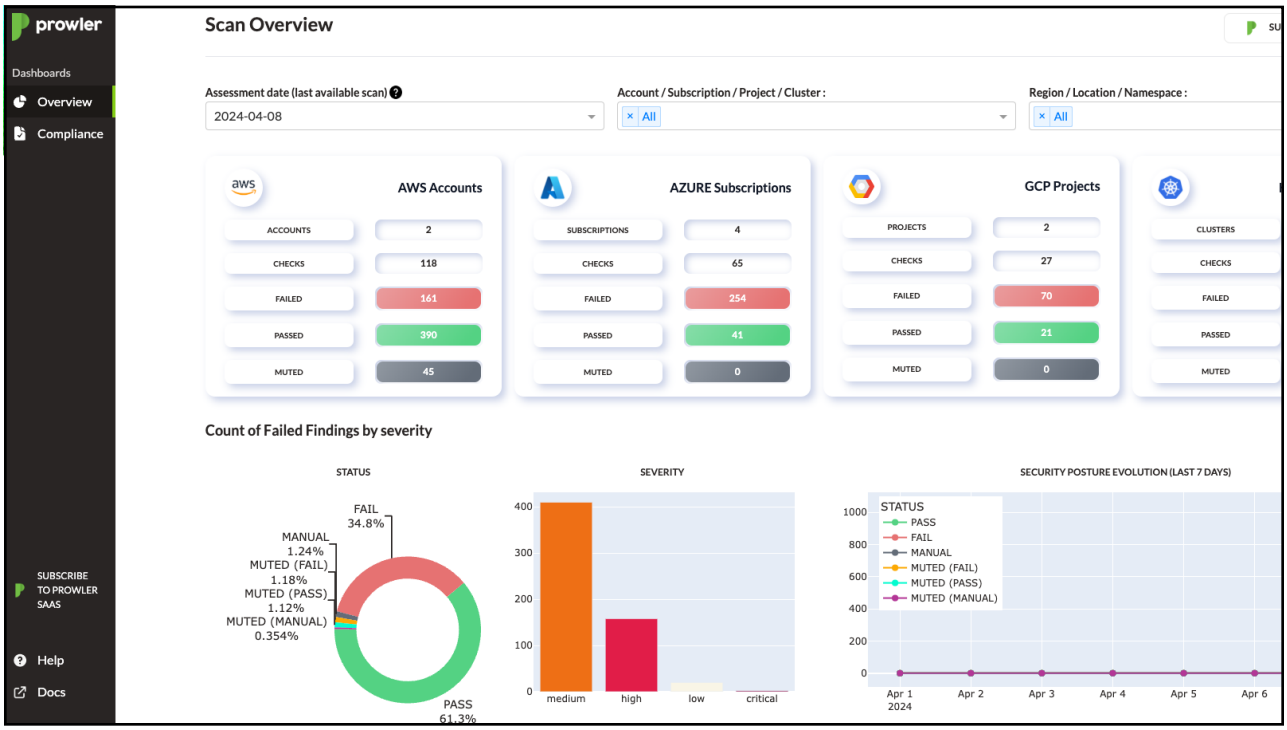
```
FAIL! us-east-1: Potential secret found in i-00[redacted]cc127 User Data
FAIL! us-east-1: Potential secret found in i-00[redacted]fb0b7 User Data
FAIL! us-east-1: Potential secret found in i-0b4[redacted]9f956 User Data
FAIL! us-east-1: Potential secret found in i-0f4[redacted]f0465 User Data
FAIL! us-east-1: Potential secret found in i-083[redacted]36651 User Data
FAIL! us-east-1: Potential secret found in i-077[redacted]0521e User Data
FAIL! us-east-1: Potential secret found in i-09e[redacted]77d78 User Data
FAIL! us-east-1: Potential secret found in i-0ac[redacted]ed82 User Data
FAIL! us-east-1: Potential secret found in i-052[redacted]38d68 User Data
FAIL! us-east-1: Potential secret found in i-0a79[redacted]ac80e User Data
FAIL! us-east-1: Potential secret found in i-004[redacted]1b8c7 User Data
FAIL! us-east-1: Potential secret found in i-058f[redacted]f0452 User Data
```

26

# ONCE UPON A TIME (3)

```
[check14] Ensure access keys are rotated every 90 days or less (Scored)
 FAIL!  evil_m[redacted]e_dev_rw has not rotated access key1 in over 90 days
 FAIL!  evil_[redacted] has not rotated access key1 in over 90 days
 FAIL!  atlan[redacted] has not rotated access key1 in over 90 days
 FAIL!  gargleblaster[redacted] has not rotated access key1 in over 90 days
 FAIL!  fed_e
 FAIL!  fed_t[redacted]-VPC
 FAIL!  iam_p
 FAIL!  iam_r
 PASS! us-west-1: Instance i-09c06004c7fb38972 associated with role gladitors-monitoring-[redacted]
 FAIL! us-west-1: Instance i-0aecf[redacted]2cc not associated with an instance role
 PASS! us-west-1: Instance i-060b[redacted]4cd0 associated with role kittle-ec2Role-dev-testing
 FAIL! us-west-1: Instance i-0e640[redacted]3fb not associated with an instance role
 FAIL! us-west-1: Instance i-0fdd1[redacted]89 not associated with an instance role
 PASS! us-west-1: Instance i-0c2d0c8cbb5ef7007 associated with role etcd-server-
[redacted]0000001
 FAIL! us-west-1: Instance i-0cf[redacted]e70ff not associated with an instance role
 PASS! us-west-1: Instance i-0722[redacted]135 associated with role EC2_Cloudwatch
 FAIL! us-west-1: Instance i-05b27[redacted]715f not associated with an instance role
 FAIL! us-west-1: Instance i-0bcc0[redacted]60 not associated with an instance role
 PASS! us-west-1: Instance i-00[redacted]77f1 associated with role s3-full-access
 PASS! us-west-1: Instance i-00d51[redacted]1df associated with role s3-full-access
 FAIL! us-west-1: Instance i-09233[redacted]d09 not associated with an instance role
 FAIL! us-west-1: Instance i-004c[redacted]e75 not associated with an instance role
 FAIL! us-west-1: Instance i-0a1[redacted]5ccf not associated with an instance role
 FAIL! us-west-1: Instance i-078a[redacted]045b1 not associated with an instance role
 FAIL! us-west-1: Instance i-0248d[redacted]f681 not associated with an instance role
```

27




28

```
v4.0.0
the handy multi-cloud security tool

Date: 2024-04-08 15:09:16

-> Using the AWS credentials below:
  · AWS-CLI Profile: default
  · AWS Regions: us-east-1
  · AWS Account: [redacted]
  · User Id: [redacted]:toni[redacted]
  · Caller Identity ARN: arn:aws:sts:[redacted]toni[redacted]

-> Using the following configuration:
  · Config File: [redacted]prowler/config/config.yaml
  · Mute List File: [redacted]prowler/config/aws_mutelist.yaml
  · Scanning unused services and resources: False

Executing 305 checks, please wait...
-> Scan completed! |[redacted]| 305/305 [100%] in 1:56.7

Overview Results:
```

| 41.8% (79) Failed | 54.5% (103) Passed | 19.05% (36) Muted |
|---|---|---|

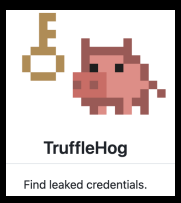
Account 552455647653 Scan Results (severity columns are for fails only):

| Provider | Service | Status | Critical | High | Medium | Low | Muted |
|---|---|---|---|---|---|---|---|
| aws | accessanalyzer | FAIL (1) | 0 | 0 | 0 | 1 | 0 |
| aws | account | FAIL (1) | 0 | 0 | 1 | 0 | 0 |
| aws | lambda | FAIL (1) | 0 | 0 | 0 | 1 | 5 |
| aws | backup | FAIL (1) | 0 | 0 | 0 | 1 | 0 |
| aws | cloudformation | FAIL (5) | 0 | 0 | 5 | 0 | 3 |
| aws | cloudtrail | FAIL (4) | 0 | 0 | 1 | 3 | 9 |
| aws | cloudwatch | FAIL (19) | 0 | 0 | 19 | 0 | 6 |

29

# (SOME) MORE TOOLS

- github.com/prowler-cloud/prowler
  *Multi-cloud OSINT tool. Enumerate public resources in AWS, Azure, and Google Cloud*
- github.com/RhinoSecurityLabs/pacu
- github.com/nccgroup/ScoutSuite
- github.com/trufflesecurity/trufflehog




- GCP
  - github.com/RhinoSecurityLabs/GCPBucketBrute
  - forsetisecurity.org/
  - cloud.google.com/asset-inventory/docs/samples/asset-quickstart-analyze-iam-policy

30

## LET'S DO BETTER

**Policy as Code doesn't stop attackers**

It makes sure there's nothing left to attack

31

## KEY TAKEAWAYS

- *Misconfiguration is not a mistake - it's the attack surface*
- *Identity is the new perimeter*
- *Your SaaS integrations are attack surfaces*
- *Complexity guarantees drift*
- *If publicly exposed + vulnerable + privileged can overlap, it will*
- *Policy as Code turns 'be careful' into 'not allowed.'*

32

# *Obrigada!*

*Kat Fitzgerald*

github.com/rnbwkat/presents
rnbwkat@infosec.exchange
rnbwkat.bsky.social
YT/@rnbwkatandtequila

evilkat@rnbwmail.com

sashatheflamingo.xyz

infosec.exchange/@sashatheflamingo
@sashatheflamingo.bsky.social

33